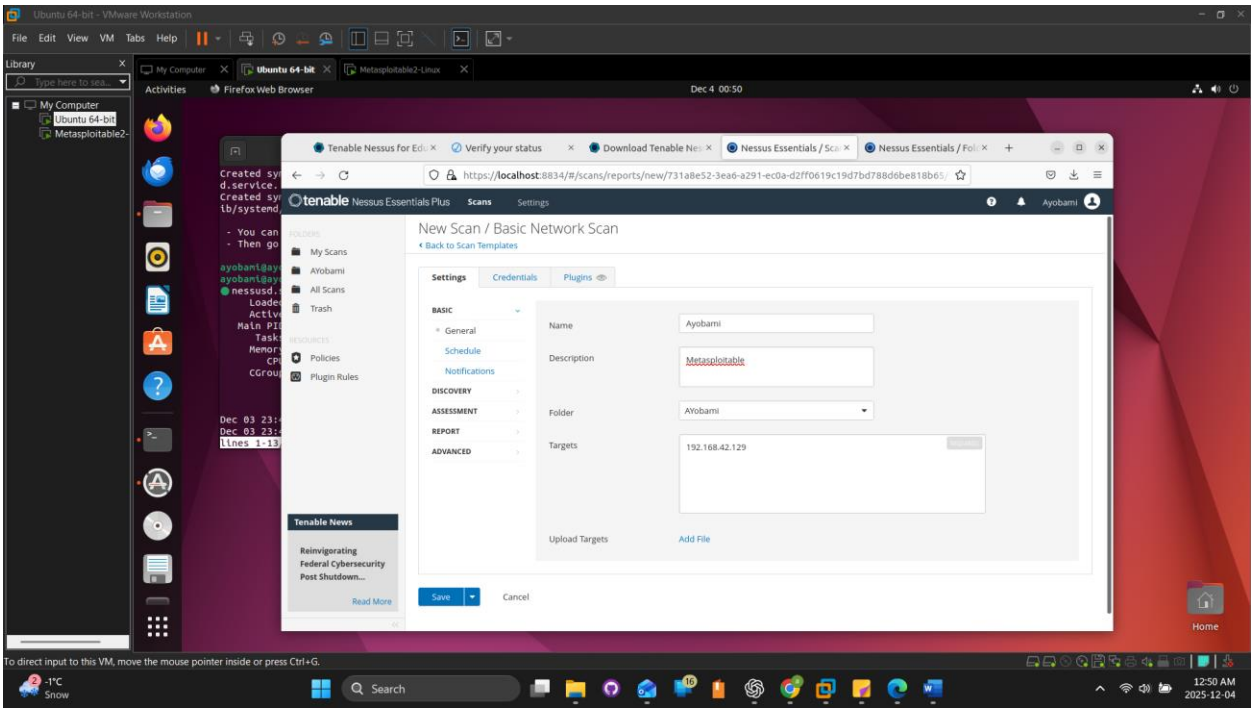
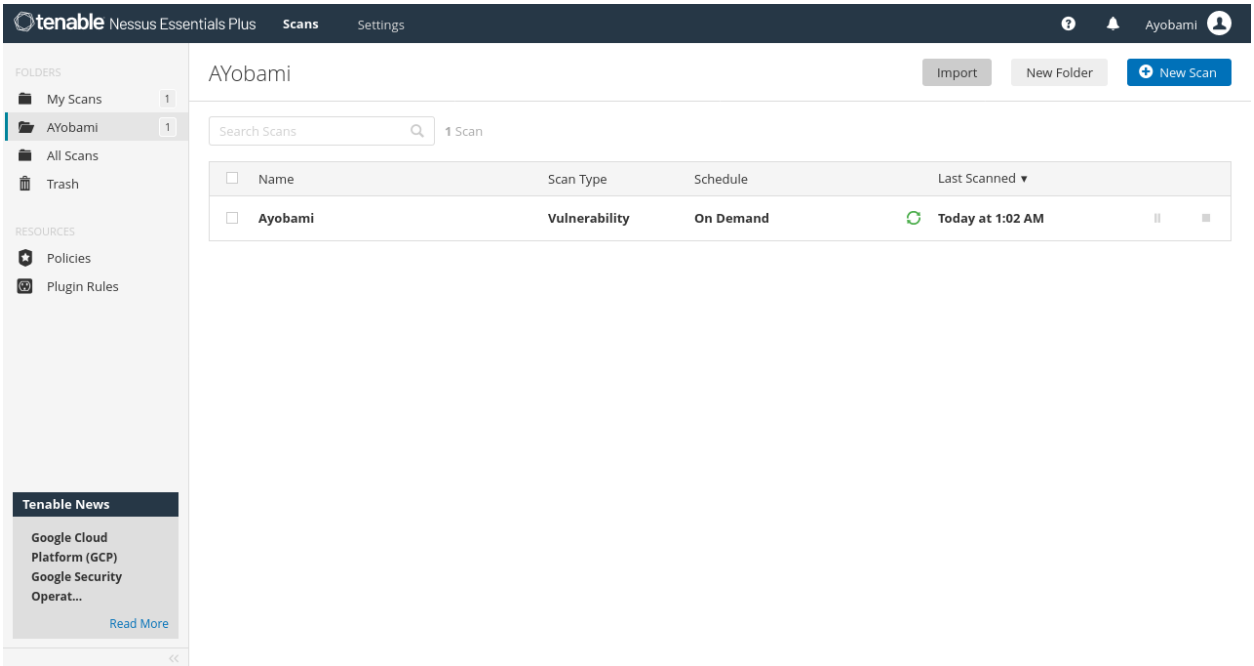
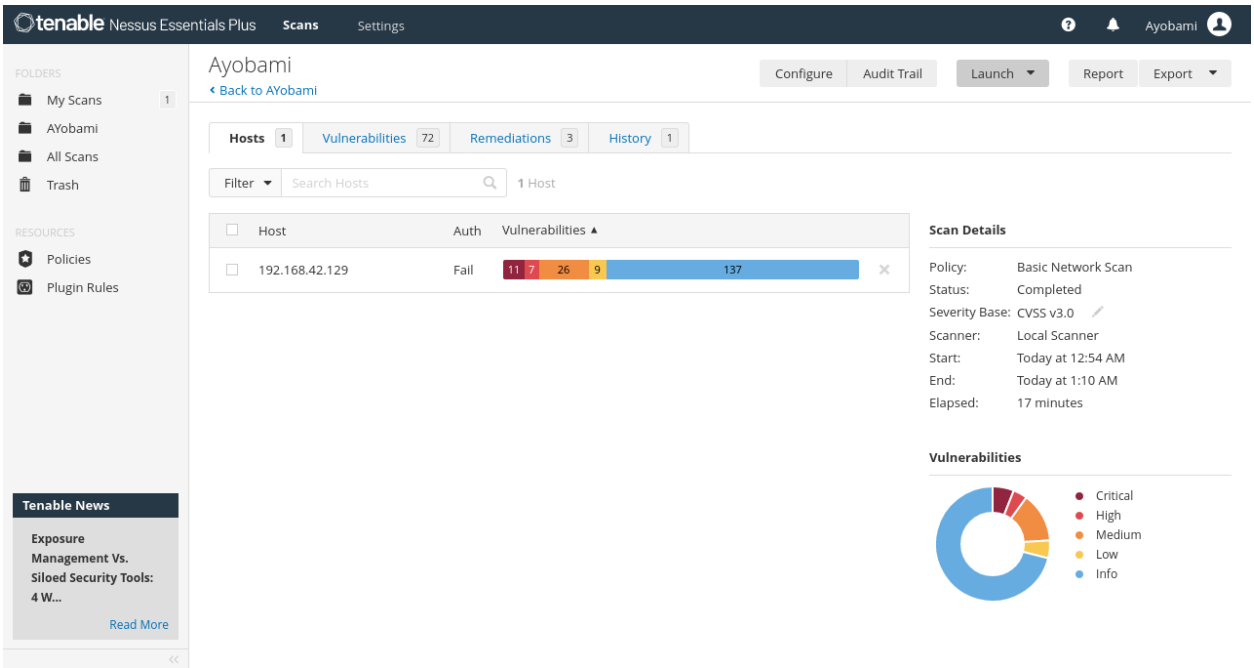
Nessus: Scanning Metasploitable VM







1. How many high, medium, and low severity vulnerabilities were found?

From your Nessus scan:

- **Critical:** 11
- **High:** 7
- **Medium:** 26
- **Low:** 9
- **Informational:** 137

tenable Nessus Essentials Plus | Scans | Settings | Ayobami

FOLDERS
- My Scans 1
- AYobami
- All Scans
- Trash

RESOURCES
- Policies
- Plugin Rules

Tenable News

Reinvigorating Federal Cybersecurity Post Shutdown...

Read More

Ayobami

Back to AYobami

Configure | Audit Trail | Launch | Report | Export

Hosts 1 | Vulnerabilities 72 | **Remediations 3** | History 1

Search Actions

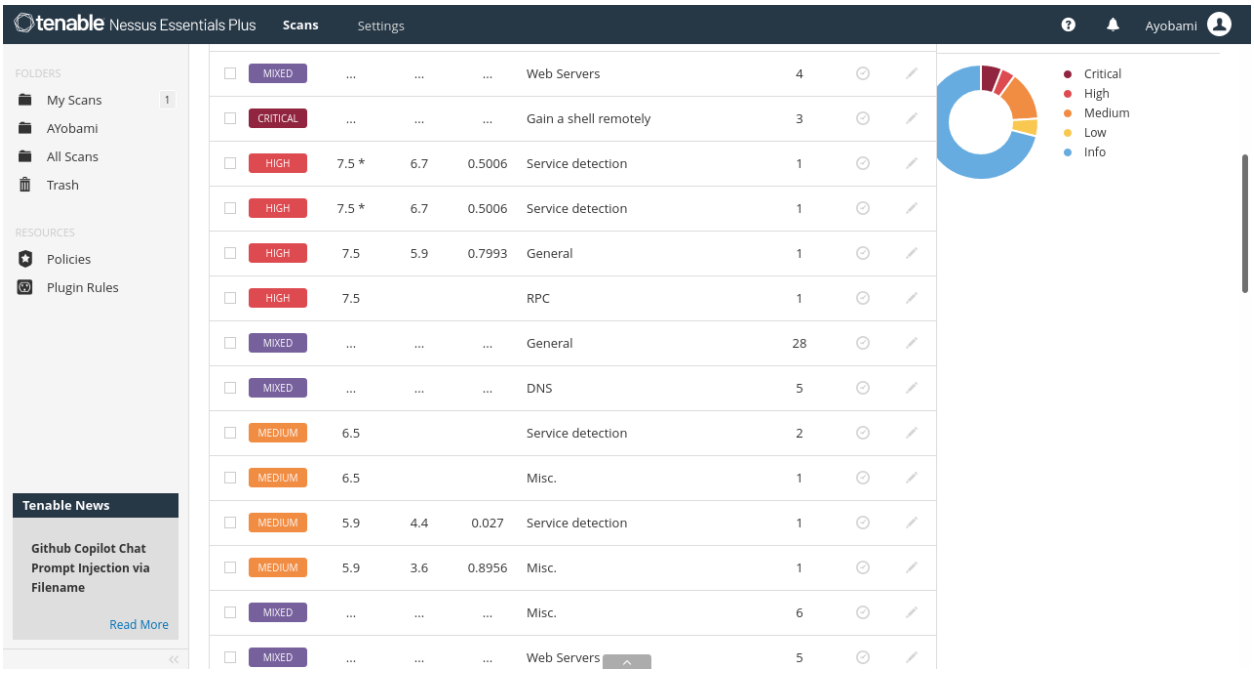
3 Actions

Action	Vulns ▾	Hosts
ISC BIND 9.x < 9.11.22, 9.12.x < 9.16.6, 9.17.x < 9.17.4 DoS: Upgrade to BIND 9.11.22, 9.16.6, 9.17.4 or later.	3	1
Samba Badlock Vulnerability: Upgrade to Samba version 4.2.11 / 4.3.8 / 4.4.2 or later.	1	1
UnrealIRCd Backdoor Detection: Re-download the software, verify it using the published MD5 / SHA1 checksums, and re-install it.	0	1

Scan Details

Policy:	Basic Network Scan
Status:	Completed
Severity Base:	CVSS v3.0
Scanner:	Local Scanner
Start:	Today at 12:54 AM
End:	Today at 1:10 AM
Elapsed:	17 minutes

1- HIGH-SEVERITY VULNERABILITY



Service Detection (CVSS 7.5 — High)

What it is:
This means Nessus identified a running service (like HTTP, SSH, FTP, or SMB) that is exposed in a way that allows attackers to learn detailed information about the service.

Why it matters:
Many services reveal:

- Software name
- Version number
- Operating system details
- Supported modules

Attackers use this to match the service to known exploits.

How it could be exploited:
If an attacker learns you are running an outdated service (example: Apache 2.2 or Samba 3.0), they can:

- Search for public exploits
- Perform targeted attacks

- Attempt remote code execution

How to fix:

- Hide unnecessary service banners
- Restrict service ports behind a firewall
- Update exposed services regularly

2 - HIGH-SEVERITY VULNERABILITY

RPC Vulnerability (High)

What it is:
The RPC (Remote Procedure Call) service is running and exposed. RPC is used for inter-process communication, but older RPC is known to have serious weaknesses.

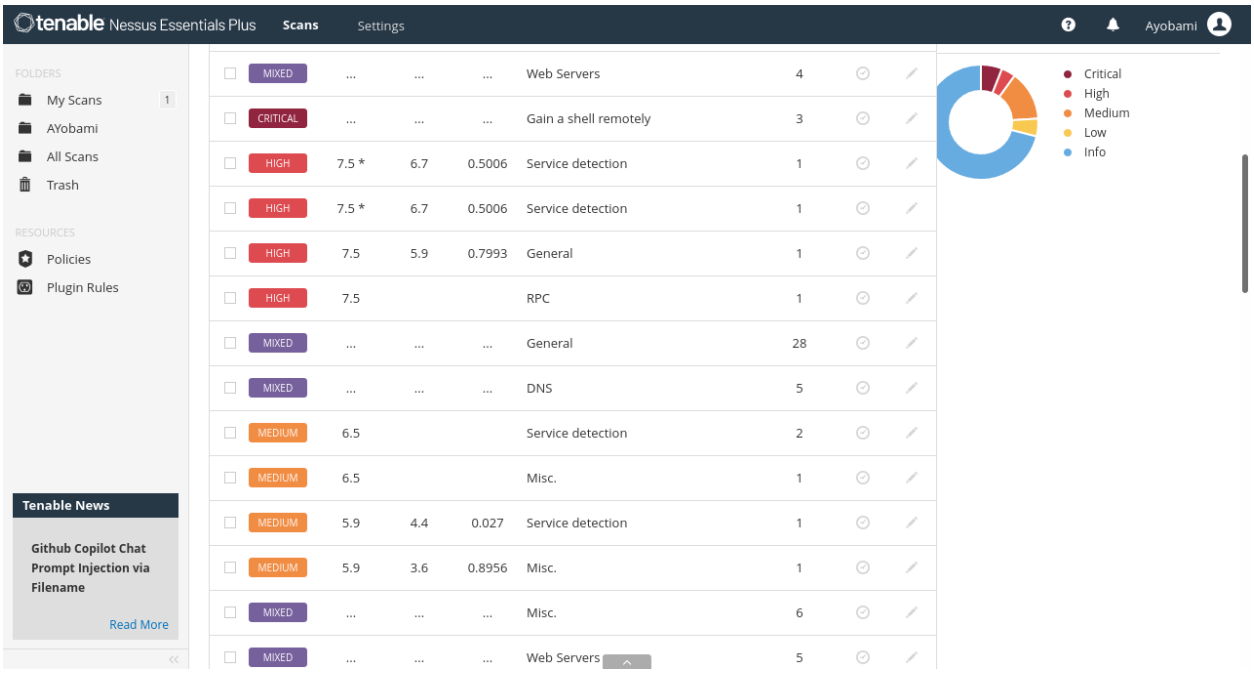
How it could be exploited:
Attackers may use RPC to:

- Gather system information
- Enumerate running services
- Trigger remote exploits (RPC has been used in major worms like Blaster)
- Gain unauthorized control

How to fix:

- Disable RPC if not required
- Apply security patches
- Restrict RPC access using firewall rules (block ports 111, 135, etc.)

1-MEDIUM-SEVERITY VULNERABILITY



Service Detection (CVSS 6.5 — Medium)

What it is:
A service responded in a way that reveals its behavior, version, and capabilities.
This is less severe than the High version but still provides useful reconnaissance data.

How it could be exploited:
Attackers can:

- Identify outdated software
- Determine which exploits might work
- Map your attack surface

How to fix:

- Disable unnecessary services
- Update service software
- Configure services to limit or hide version information

2- MEDIUM-SEVERITY VULNERABILITY

Miscellaneous Vulnerability (CVSS 6.5 — Medium)

What it is:
This refers to general misconfigurations or behaviors that expose the system to risk — for example outdated modules, insecure configuration options, or miscellaneous findings.

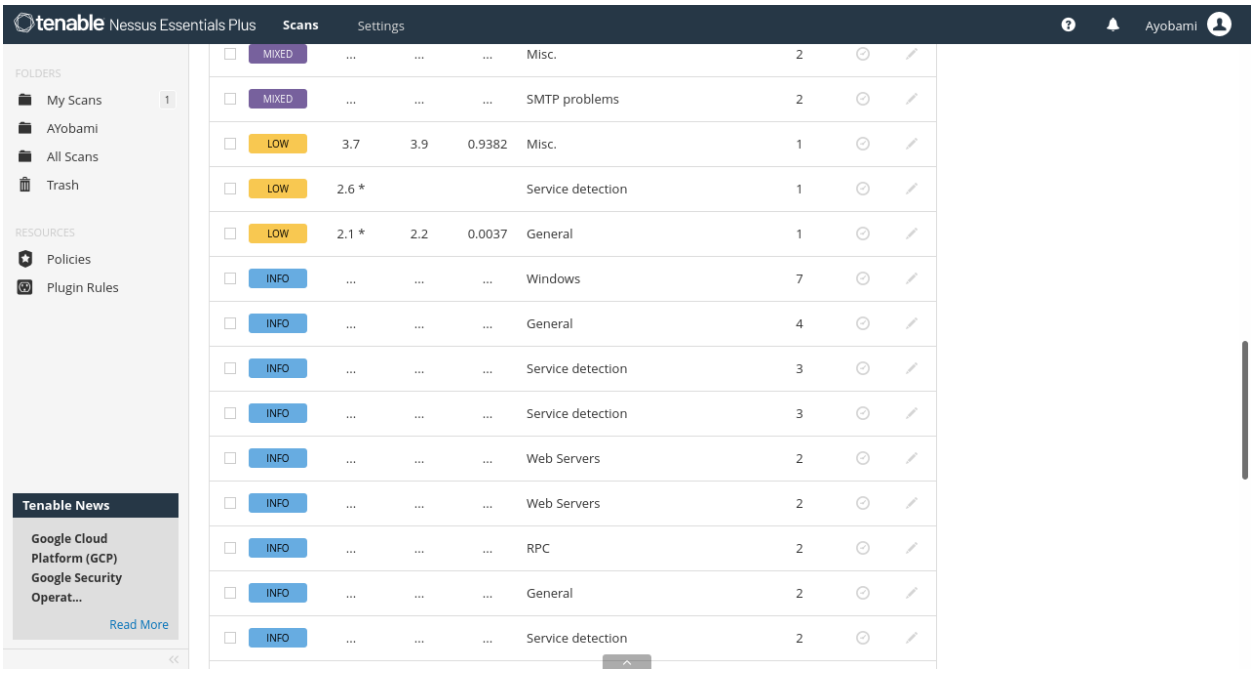
How it could be exploited:
Attackers could:

- Use the misconfiguration to learn more about your system
- Chain it with other vulnerabilities
- Use it as a stepping stone in a larger attack

How to fix:

- Review the specific service configuration
- Disable unnecessary features
- Apply vendor updates or patches

LOW-SEVERITY VULNERABILITY



Miscellaneous (Low) — CVSS 3.7 / 2.6 / 2.1

What it is:
These are minor misconfigurations or informational leaks that don't pose immediate danger but provide small clues to an attacker.

Examples include:

- Services revealing harmless but unnecessary details
- Minor protocol misconfigurations
- Weak but not exploitable service responses

How it could be exploited:
Attackers might use this information to:

- Profile the system
- Understand the OS or service versions
- Support larger attacks

How to fix:

- Clean up configuration files
- Disable unnecessary service responses
- Keep software updated